

Cybersecurity

Introduction to Pen Testing and OSINT

Lesson 15.1



Learning Objectives

By the end of today's class, you will be able to:

- 1 Understand the role of a pen tester in assessing a business's security.
- 2 Collect domain information by using OSINT techniques and tools like Google hacking, Shodan, and certificate transparency.
- 3 Use Shodan and Recon-ng to discover domain server information.



Welcome



Introduction to Penetration Testing

Introduction to Penetration Testing

Today, we will cover the following:



An **introduction** to penetration testing and its business goals

A **high-level overview** of the various stages of a pen test engagement

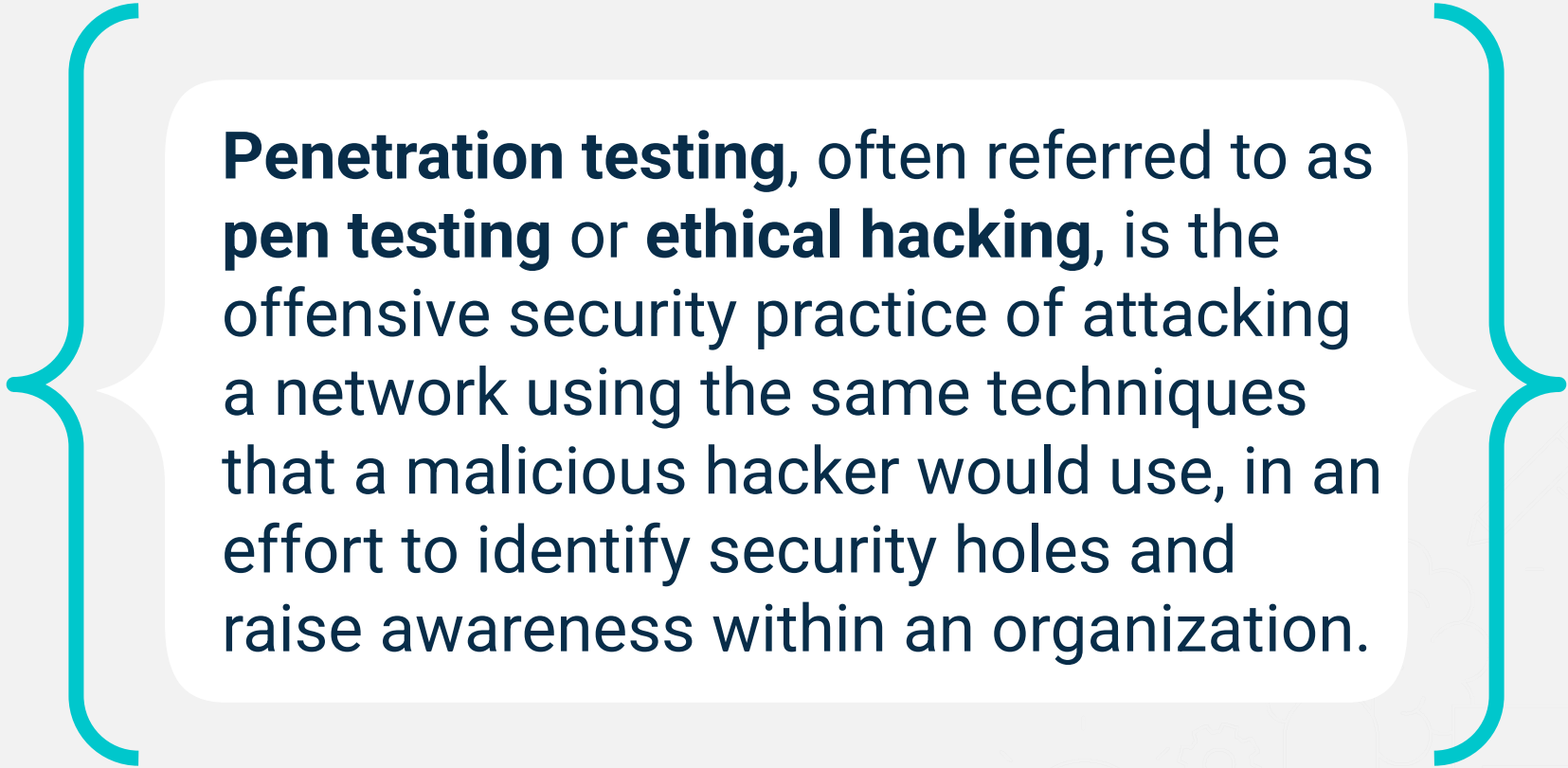
A **deep dive** into the first step of a penetration test: planning and reconnaissance

Important!

The techniques that we'll learn in this unit can be used to break into networks and do serious damage to an organization's infrastructure.

- This is **illegal** when done without permission.
- The tools and techniques we'll discuss are serious, and misusing them has serious consequences.
- Do not practice these techniques against computers that you do not own or have clear written permission to interact with.





Penetration testing, often referred to as **pen testing** or **ethical hacking**, is the offensive security practice of attacking a network using the same techniques that a malicious hacker would use, in an effort to identify security holes and raise awareness within an organization.

Penetration Testing

Organizations hire pen testers to assess their security controls. Pen testers find flaws in those controls, help the organization understand these flaws, and provide recommendations about which vulnerabilities to prioritize and how to fix them.

- Pen tests are often administered by consultancies, which can take an “outside” view of a client’s networks.
- In the simplest terms, pen testers aim to break into a client's machine, infrastructure, or even physical premises to help the client improve their security.



Penetration Testing

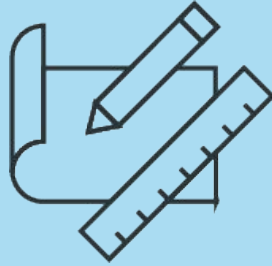
Penetration testing is often referred to as an **engagement**.

Pen testers, unlike **malicious hackers**, begin engagement only after receiving permission.

Pen testers use a combination of automated and manual tools to:

- Research vulnerabilities
- Craft phishing emails
- Manually exploit hosts
- Write shell code





Module Overview and **Penetration Testing Phases**



This Week's Scenario



This week, you will play the role of consultants at GoodCorp who have been hired to conduct a penetration test against **MegaCorpOne**.

- MegaCorpOne is an organization that specializes in disruptive innovation in the nanotechnology industry and has hired GoodCorp to run a penetration test.
- You will be tasked with going through the penetration testing engagement to assess MegaCorpOne's security.
- You will conclude the test with a report of your findings, so **be sure to keep all of your findings** as you proceed through the penetration testing activities.

Penetration testers follow a methodology during an engagement that is designed to mimic that of an actual attack.

This helps network defenders understand how effective their organization's defenses are.



Planning and
reconnaissance

Scanning

Exploitation

Post exploitation

Reporting

Pen Testing Phases

An engagement consists of five phases:

01A	Planning	Define the purpose and scope of the test, and sign all legal contracts.
01B	Reconnaissance	Obtain publicly available information about your target.
02	Scanning	Use tools to run a scan against your target to gather information, such as open ports, and run services to determine potential vulnerabilities.
03	Exploitation	Attack the vulnerabilities discovered in the previous steps to gain access to the target.
04	Post exploitation	Gather valuable information from the compromised systems.
05	Reporting	Report on the previous five steps to provide a summary of actions taken, findings, and recommended mitigations.

Module Progression

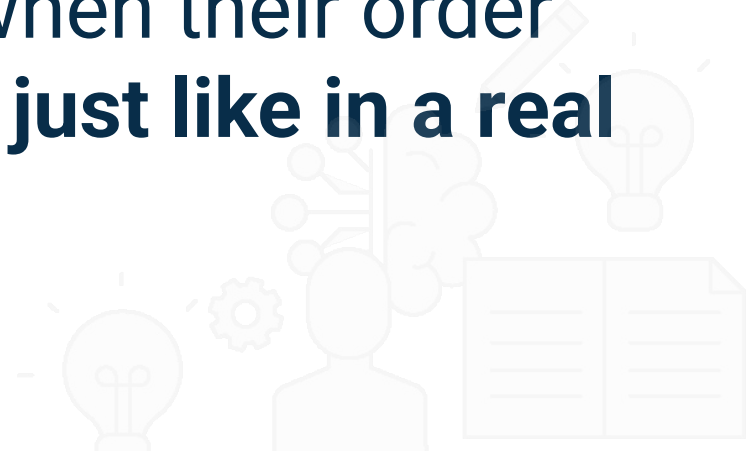
Over the four classes in this unit, we will proceed through these five phases as we conduct a penetration test against MegaCorpOne.

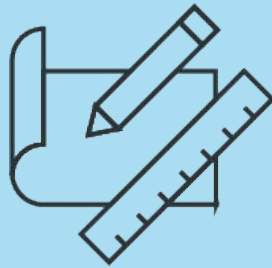


Keep your findings from each activity. You will use them on the fourth day when you create your penetration test report.



While we've shown these phases sequentially, there are times when steps are skipped, repeated, or when their order is switched – **just like in a real attack.**





Planning the Penetration Test

Phase 1: Planning

The planning step is an interaction between the organization and the pen testing team. It helps pen testers thoroughly understand the client's needs before beginning the test.

Most businesses' primary interest is not how attackers might gain access to their networks.

Instead, their main concern is the major consequences that an exploited vulnerability may have for their reputation, operations, or bottom line.



Purpose and Scope

Planning usually begins with a kick-off meeting, during which clients work with pen testers to determine the purpose and scope of the project.





Phase 1: Planning

The primary deliverable from this stage is a document summarizing the:



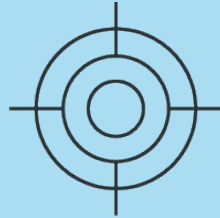
Engagement's purpose



Scope



Associated details such as timeframe and emergency contacts



Types of Penetration Testing

Types of Penetration Testing

There are three types of penetration tests:

No view



black box

Full view



Also known as
white box

Partial view



Also known as
gray box

No-View Pen Testing

In no-view testing, the pen tester simulates a malicious hacker who has no prior knowledge of the target system and network:

- The pen tester is paid to learn and exploit as much as they can about the network using **only the tools publicly available to an attacker on the internet**.
- For example, they may know only the company name and have to find various key resources, like IP ranges and access credentials.



Full-View Pen Testing

In full-view testing, the pen tester is given full knowledge of the system or network:

- This knowledge allows them to tear apart subtle security issues on behalf of their clients.
- Full-view pen testing is most appropriate when the client wants a detailed analysis of all potential security flaws, rather than exposed and visible vulnerabilities.
- Full-view testers are given: **network diagrams, access credentials to the networks, system names, usernames, emails, and phone numbers.**



Partial-View Pen Testing

Partial-view pen testing is performed by the in-house system or network admin.

Regardless of the scenario, the main deliverable for any pen tester is a report that summarizes their findings and recommendations for improvements.



**Some
Knowledge**



The main deliverable for any pen tester is **a report** that summarizes their findings and recommendations for improvements.



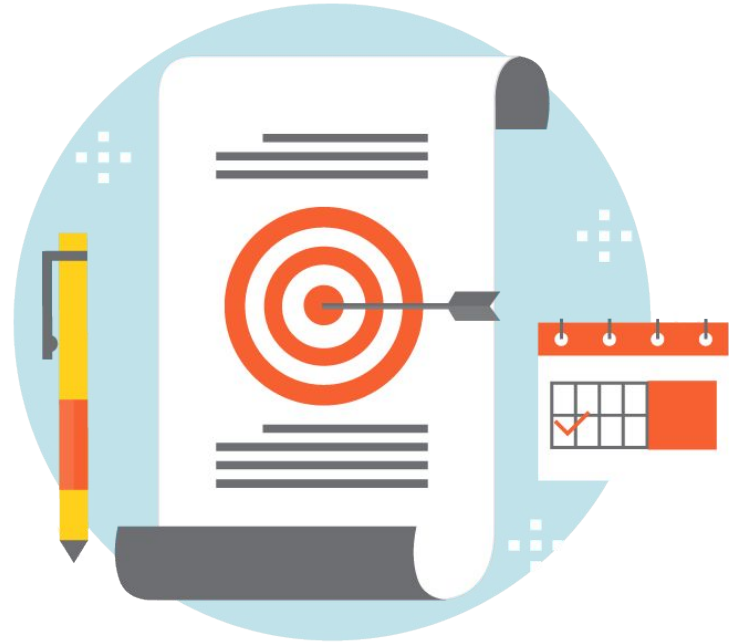
Statements of Work and Legal Indemnification

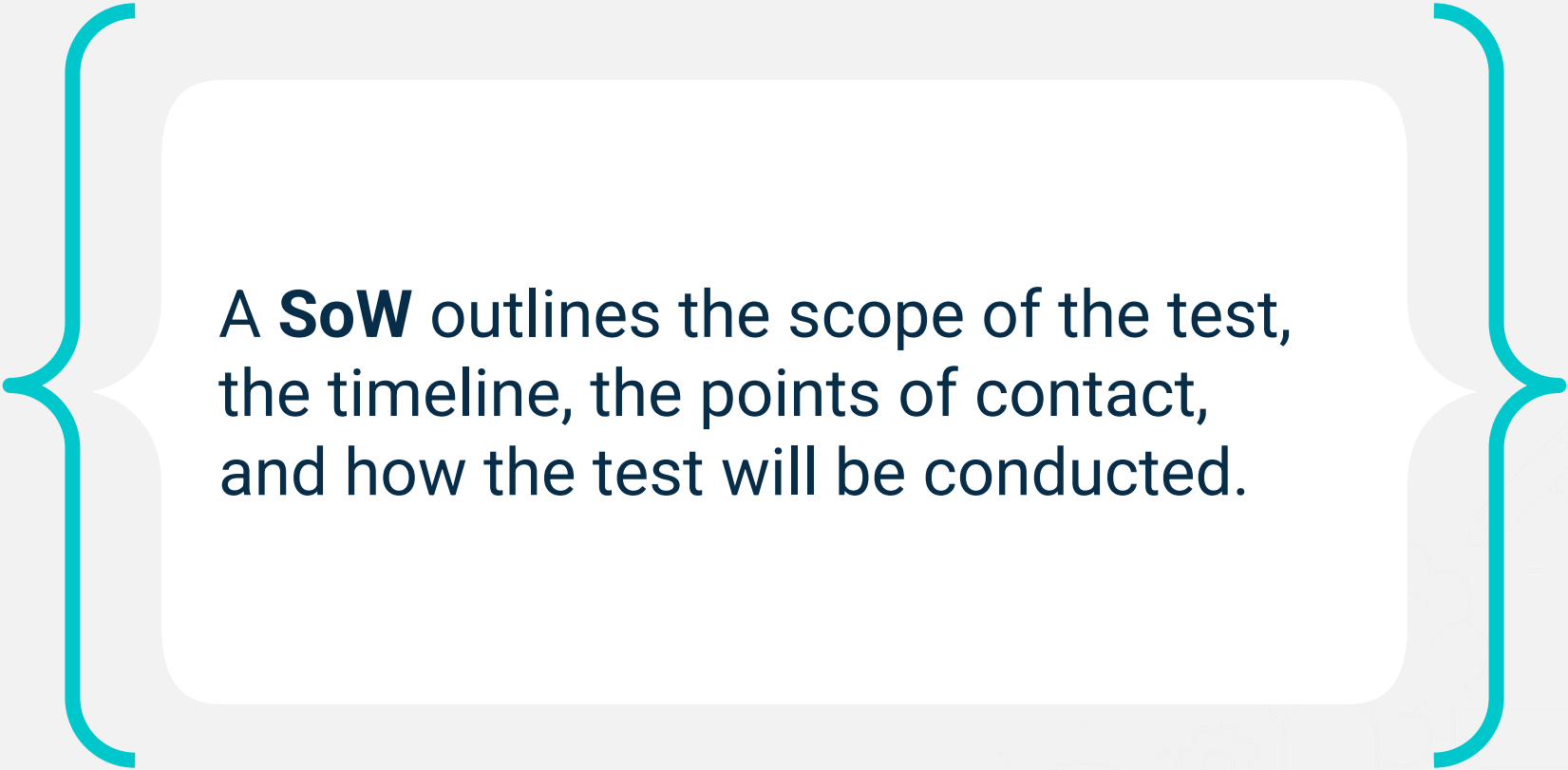
Statements of Work & Legal Indemnification

Before beginning a security assessment, several legal steps must be completed.

Since penetration testing is hacking, the entity being hacked **must consent to the test**.

To protect the assessors from legal ramifications, a **statement of work (SoW)** must be agreed upon and signed by both parties.

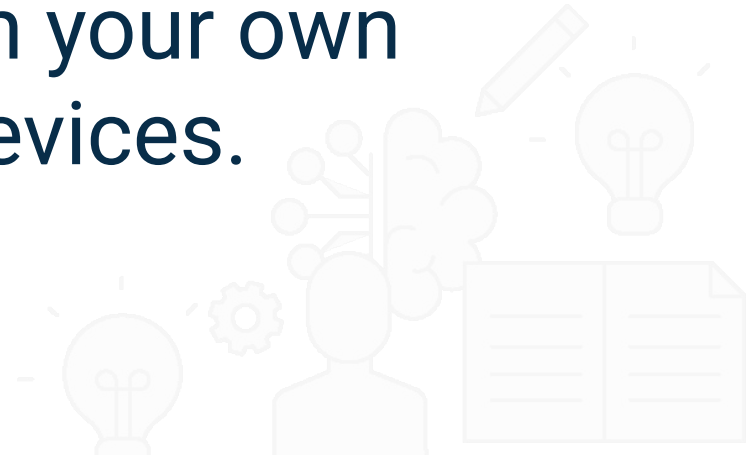




A **SoW** outlines the scope of the test,
the timeline, the points of contact,
and how the test will be conducted.



Penetration testing without a contractual agreement is **illegal**, unless it is conducted on your own network or devices.





Scenario 1:

A financial institution asks you to perform a penetration test on their private network.

They will give you access to all the credentials and architecture diagrams that you may need.

You will also meet with them beforehand to sign a contract clearly illustrating the scope and purpose of the test.



Scenario 1:

A financial institution asks you to perform a penetration test on their private network.

They will give you access to all the credentials and architecture diagrams you may need.

You will also meet with them beforehand to sign a contract clearly illustrating the scope and purpose of the test.



This is a **legal** full-view penetration test, because you have signed a contract before you begin your assessment.

Scenario 2:



A friend has verbally asked you to perform a penetration test on a social media website they just joined as they want to make sure their information is safe.



Scenario 2:

A friend has verbally asked you to perform a penetration test on a social media website they just joined as they want to make sure their information is safe.



This is an illegal no-view test, because neither the friend nor you own the social media website network or devices, and the social media website has not granted permission or signed a contract authorizing this test.



Let's recap

Summary



Penetration testing, often referred to as **pen testing** or **ethical hacking**, is the offensive security practice of attacking a network using the same techniques that a malicious hacker uses.



The five phases of a pen testing engagement are: **Planning and Reconnaissance**, **Scanning**, **Exploitation**, **Post-Exploitation**, and **Reporting**.



During the planning phase, the engagement's scope and purpose are defined.



The **scope** includes the type of penetration test that will be run. Types include **no view**, **full view**, and **partial view**.



A **SoW** is also completed during the planning phase. It outlines the scope of the test, the timeline, the points of contact, and how the test will be conducted.



Activity:

Types of Penetration Testing

In this activity, you will work as a security consultant at GoodCorp, who's been hired to perform penetration tests.

- You have just been given a list of potential contract opportunities.
- Your first task is to evaluate the list and determine:
 - Whether the assessment is legal or illegal
 - The type of penetration test being requested

Suggested Time:
15 Minutes



Time's up!
Let's review



Questions?





Intro to **MITRE ATT&CK®**

MITRE ATT&CK®

The **MITRE ATT&CK® Matrix** provides a visual representation of all the **techniques, tactics, and procedures (TTPs)** that may be performed throughout an assessment.

We will use this matrix as a reference for the TTPs that we will conduct throughout the next two weeks.

The screenshot shows the MITRE ATT&CK Enterprise Matrix web application. The browser address bar displays 'attack.mitre.org/matrices/enterprise/'. The page features a red header with the MITRE ATT&CK logo and navigation links for Matrices, Tactics, Techniques, Mitigations, Groups, Software, Resources, Blog, and Contribute. A search bar is located on the right. The main content area is titled 'Enterprise Matrix' and includes a description: 'Below are the tactics and techniques representing the MITRE ATT&CK® Matrix for Enterprise. The Matrix contains information for the following platforms: Windows, macOS, Linux, PRE, Azure AD, Office 365, Google Workspace, SaaS, IaaS, Network, Containers.' A sidebar on the left lists categories: Enterprise, PRE, Windows, macOS, Linux, Cloud, Network, Containers, Mobile, and ICS. The main table displays various tactics and techniques, including Reconnaissance (10 techniques), Resource Development (7 techniques), Initial Access (9 techniques), Execution (12 techniques), Persistence (19 techniques), Privilege Escalation (13 techniques), Defense Evasion (39 techniques), Credential Access (15 techniques), Discovery (27 techniques), Lateral Movement (9 techniques), and Collection (17 techniques). Each tactic is expanded to show a list of associated techniques.

Tactic	Techniques
Reconnaissance	Active Scanning (2), Gather Victim Host Information (4), Gather Victim Identity Information (3), Gather Victim Network Information (6), Gather Victim Org Information (6), Phishing for Information (3), Search Closed Sources (2), Search Open Technical Databases (3), Search Open Websites/Domains (2), Search Victim-Owned Websites
Resource Development	Acquire Infrastructure (6), Compromise Accounts (2), Compromise Infrastructure (6), Develop Capabilities (4), Establish Accounts (2), Phishing (3), Obtain Capabilities (3), Stage Capabilities (3), Supply Chain Compromise (3), Software Trusted Relationship, Valid Accounts (4)
Initial Access	Drive-by Compromise, Exploit Public-Facing Application, External Remote Services, Hardware Additions, Phishing (3), Replication Through Removable Media, Supply Chain Compromise (3), Trusted Relationship, Valid Accounts (4)
Execution	Command and Scripting Interpreter (3), Container Administration Command, Deploy Container, Exploitation for Client Execution, Inter-Process Communication (3), Native API, Scheduled Task/Job (7), Shared Modules, Software Deployment Tools, System Services (2), User Execution (3)
Persistence	Account Manipulation (2), BITS Jobs, Boot or Logon Autostart Execution (14), Boot or Logon Initialization Scripts (3), Browser Extensions, Compromise Client Software Binary (7), Create Account (2), Create or Modify System Binary (7), Event Triggered Execution (13), External Remote Services, Hijack Execution Flow (11), Process Injection (11)
Privilege Escalation	Abuse Elevation Control Mechanism (4), Access Taken Manipulation (3), BITS Jobs, Build Image on Host, Deobfuscate/Decode Files or Information, Forced Authentication, Boot or Logon Initialization Scripts (3), Direct Volume Access, Domain Policy Modification (2), Domain Trust, Execution Guardrails (3), Exploitation for Defense Evasion, File and Directory Permissions Modification (2), Hide Artifacts (7), Hijack Execution Flow (11), Impair Defenses (7), Indicator Removal on Host
Defense Evasion	Brute Force (4), Credentials from Password Store (3), Exploitation for Credential Access, Forced Authentication, Forge Web Credentials (2), Input Capture (4), Map-in-the-Middle (2), Modify Authentication Process (4), Network Sniffing, OS Credential Dumping (8), Steal Application Access Token, Steal or Forge Authentication
Credential Access	Brute Force (4), Credentials from Password Store (3), Exploitation for Credential Access, Forced Authentication, Forge Web Credentials (2), Input Capture (4), Map-in-the-Middle (2), Modify Authentication Process (4), Network Sniffing, OS Credential Dumping (8), Steal Application Access Token, Steal or Forge Authentication
Discovery	Account Discovery (4), Application Window Discovery, Browser Bookmark Discovery, Cloud Infrastructure Discovery, Cloud Service Dashboard, Cloud Service Discovery, Container and Resource Discovery, Domain Trust Discovery, File and Directory Discovery, Network Service Scanning, Network Share Discovery, Network Sniffing, Password Policy Discovery, Peripheral Device Discovery
Lateral Movement	Exploitation of Remote Services, Internal Spearphishing, Lateral Tool Transfer, Remote Service Session Hijacking (2), Remote Services (3), Application Through Removable Media, Software Deployment Tools, Taint Shared Content, Use Alternate Authentication Material (4)
Collection	Archive Collected Data (2), Audio Collection, Automated Collection, Clipboard, Data from Cloud Storage Object, Data from Information Repository, Data from Local Storage, Data from Network Shared Content, Data from Remote Storage, Data from User Email Collection

MITRE ATT&CK®

The matrix consists of the following:

Tactics/Headers

- Each header represents a **tactic**.
- For example, the first tactic listed is **reconnaissance**.
- It's listed first because attackers conduct reconnaissance on a target before actually performing any exploitation.

MITRE | ATT&CK®

Home > Matrices > Enterprise

Enterprise Matrix

Below are the tactics and techniques representing the MITRE ATT&CK® Matrix for Enterprise. The Matrix contains information for the following platforms: Windows, macOS, Linux, PRE, Azure AD, Office 365, Google Workspace, SaaS, IaaS, Network, Containers.

View on the ATT&CK® Navigator

Version Permalink

layout: side ▾ show sub-techniques hide sub-techniques help

Reconnaissance 10 techniques	Resource Development 7 techniques	Initial Access 9 techniques	Execution 12 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 39 techniques	Credential Access 15 techniques	Discovery 27 techniques	Lateral Movement 9 techniques	Collection 17 techniques
Active Scanning (2)	Acquire Infrastructure (4)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (4)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Brute Force (16)	Account Discovery (4)	Exploitation of Remote Services	Archive Collection (Data) (1)
Gather Victim Host Information (4)	Compromise Accounts (2)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs	Access Token Manipulation (4)	Access Token Manipulation (4)	Credentials from Password Stores (3)	Application Window Discovery	Internal Spearfishing	Audio Collection (1)
Gather Victim Identity Information (3)	Compromise Infrastructure (4)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (14)	Access Token Manipulation (4)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Lateral Tool Transfer	Automated Collection (1)
Gather Victim Network Information (4)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (4)	Boot or Logon Autostart Execution (14)	Decfuscate/Decode Files or Information	Forced Authentication	Cloud Service Dashboard	Remote Service Session Hijacking (2)	Data from Cloud Storage Object (1)
Gather Victim Org Information (4)	Establish Accounts (2)	Obtain Capabilities (4)	Inter-Process Communication (2)	Browser Extensions	Boot or Logon Initialization Scripts (4)	Deploy Container	Forge Web Credentials (2)	Cloud Service Discovery	Remote Services (4)	Data from Configuration Repository (1)
Pushing for Information (3)	Obtain Capabilities (4)	Replication Through Removable Media	Native API	Compromise Client Software Binary	Create or Modify System Process (4)	Domain Policy Modification (2)	Input Capture (4)	Container and Resource Discovery	Replication Through Removable Media	Data from Information Repository (1)
Search Closed Sources (3)	Stage Capabilities (3)	Supply Chain Compromise (3)	Shared Modules	Create Account (4)	Domain Policy Modification (2)	Execution Guardrails (1)	Man-in-the-Middle (2)	Domain Trust Discovery	Software Deployment Tools	Data from Network Shared Content (1)
Search Open Technical Databases (3)	Trusted Relationship	Software Deployment Tools	System Services (2)	Create or Modify System Process (4)	Escape to Host	Exploitation for Defense Evasion	Modify Authentication Process (4)	File and Directory Scanning	Taint Shared Content	Data from Network Shared Content (1)
Search Open Websites/Domains (2)	Valid Accounts (4)	User Execution (3)	Windows Management Instrumentation	Event Triggered Execution (13)	Event Triggered Execution (13)	File and Directory Scanning	Network Stuffing	Network Service Scanning	Use Alternate Authentication Material (4)	Data from Network Shared Content (1)
Search Victim-Owned Websites				Exploitation for Privilege Escalation	Exploitation for Privilege Escalation	Hide Artifacts (7)	OS Credential Dumping (9)	Network Stuffing	Use Alternate Authentication Material (4)	Data from Network Shared Content (1)
				External Remote Services	Hijack Execution Flow (11)	Hijack Execution Flow (11)	Steal Application Access Token	Password Policy Discovery		Data from Network Shared Content (1)
				Hijack Execution Flow (11)	Process Injection (11)	Indicator Removal on Host	Steal or Forge Keyboard	Peripheral Device Discovery		Email Collection (1)

MITRE ATT&CK®

The matrix consists of the following:

Techniques/Rows

- Each row under the header is a technique.
- For each tactic, there are multiple techniques.
- For example, during reconnaissance, an attacker may use active scanning to gather information about a target, or they may search open technical databases to gather similar information.



The screenshot shows the MITRE ATT&CK Enterprise Matrix website. The navigation bar includes links for Matrices, Tactics, Techniques, Mitigations, Groups, Software, Resources, Blog, and Contribute. The left sidebar lists various platforms: PRE, Windows, macOS, Linux, Cloud, Network, Containers, Mobile, and ICS. The main content area displays the 'Enterprise Matrix' with a table of tactics and techniques. The tactics listed are Reconnaissance (10 techniques), Resource Development (7 techniques), Initial Access (9 techniques), Execution (12 techniques), Persistence (19 techniques), Privilege Escalation (13 techniques), Defense Evasion (39 techniques), Credential Access (15 techniques), Discovery (27 techniques), Lateral Movement (9 techniques), and Collection (17 techniques). The 'Reconnaissance' column is highlighted, showing techniques such as Active Scanning, Gather Victim Host Information, Gather Victim Identity Information, Gather Victim Network Information, Gather Victim Org Information, Phishing for Information, Search Closed Sources, Search Open Technical Databases, Search Open Websites/Domains, and Search Victim-Owned Websites.

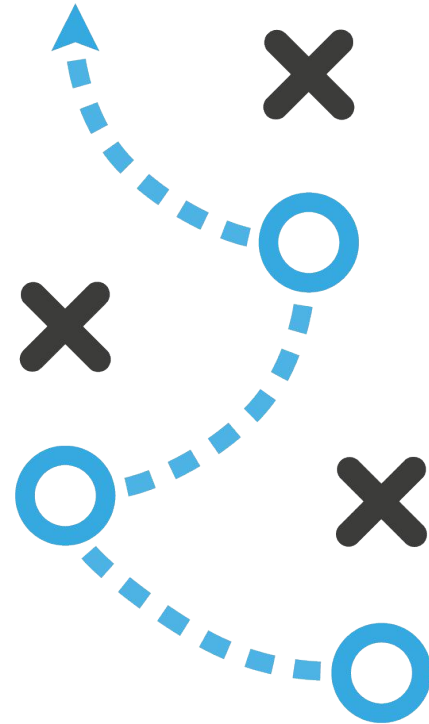
Tactic	Techniques
Reconnaissance	Active Scanning, Gather Victim Host Information, Gather Victim Identity Information, Gather Victim Network Information, Gather Victim Org Information, Phishing for Information, Search Closed Sources, Search Open Technical Databases, Search Open Websites/Domains, Search Victim-Owned Websites
Resource Development	Acquire Infrastructure, Compromise Accounts, Compromise Infrastructure, Develop Capabilities, Establish Accounts, Obtain Capabilities, Replication Through Removable Media, Stage Capabilities, Supply Chain Compromise, Trusted Relationship, Windows Management Instrumentation
Initial Access	Drive-by Compromise, Exploit Public-Facing Application, External Remote Services, Hardware Additions, Pushing, Replication Through Removable Media, Supply Chain Compromise, Trusted Relationship, Valid Accounts
Execution	Command and Scripting Interpreter, Container Administration Command, Deploy Container, Exploitation for Client Execution, Inter-Process Communication, Native API, Scheduled Task/Job, Shared Modules, Software Deployment Tools, System Services, User Execution
Persistence	Account Manipulation, BITS Jobs, Boot or Logon Autostart Execution, Boot or Logon Initialization Scripts, Browser Extensions, Compromise Client Software Binary, Create Account, Create or Modify System Process, Event Triggered Execution, Event Triggered Execution, External Services, Hijack Execution Flow, Process Injection
Privilege Escalation	Abuse Elevation Control Mechanism, Access Token Manipulation, Access Token Manipulation, Boot or Logon Autostart Execution, Boot or Logon Initialization Scripts, Browser Extensions, Create or Modify System Process, Domain Policy Modification, Domain Policy Modification, Escape to Host, Event Triggered Execution, Exploitation for Privilege Escalation, External Services, Hijack Execution Flow, Process Injection
Defense Evasion	Abuse Elevation Control Mechanism, Access Token Manipulation, BITS Jobs, Build Image on Host, Decfuscate/Decode Files or Information, Deploy Container, Direct Volume Access, Domain Policy Modification, Execution Guardrails, Exploitation for Defense Evasion, File and Directory Permissions Modification, Hide Artifacts, Hijack Execution Flow, Indicator Removal on Host, Process Injection
Credential Access	Brute Force, Credentials from Password Stores, Exploitation for Credential Access, Forced Authentication, Forge Web Credentials, Input Capture, Man-in-the-Middle, Modify Authentication Process, Network Sniffing, OS Credential Dumping, Steal Application Access Token, Steal or Forge Kerberos
Discovery	Account Discovery, Application Window Discovery, Browser Bookmark Discovery, Cloud Infrastructure Discovery, Cloud Service Dashboard, Cloud Service Discovery, Container and Resource Discovery, Domain Trust Discovery, File and Directory Discovery, Network Service Scanning, Network Share Discovery, Network Sniffing, Password Policy Discovery, Peripheral Device Discovery
Lateral Movement	Exploitation of Remote Services, Internal Spearphishing, Lateral Tool Transfer, Remote Service Session Hijacking, Remote Services, Replication Through Removable Media, Software Deployment Tools, Taint Shared Content, Use Alternate Authentication Material
Collection	Archive Collection, Data from Local System, Data from Network, Data from Remote System, Data from Shared Content, Data from System, Data from User, Data from Web, Data from Web Services, Data from Web Services, Data from Web Services, Data from Web Services

MITRE ATT&CK®

It is a “**hacker’s playbook.**”

The matrix is comprehensive, meaning that virtually every potential attack falls under a tactic and maps to a specific technique.

As a penetration tester, it’s beneficial to map out the techniques that you performed in an assessment so that the customer can learn which TTPs were successful and what needs to be addressed.



MITRE ATT&CK®

This is a powerful matrix to follow and reference

Comprehensive

It is comprehensive and includes almost every possible tactic or technique that an attacker could employ during a hack.

Reporting

In your final report, it provides a way to refer to tactics and techniques that an attacker would use in a manner that less-technical staff can understand.

Categorizing

It helps create a more comprehensive report by categorizing specific security deficiencies.

MITRE ATT&CK®

This week's unit will follow the MITRE ATT&CK® Matrix tactics from left to right. We won't cover every tactic due to time constraints, but we'll begin by learning about reconnaissance today.

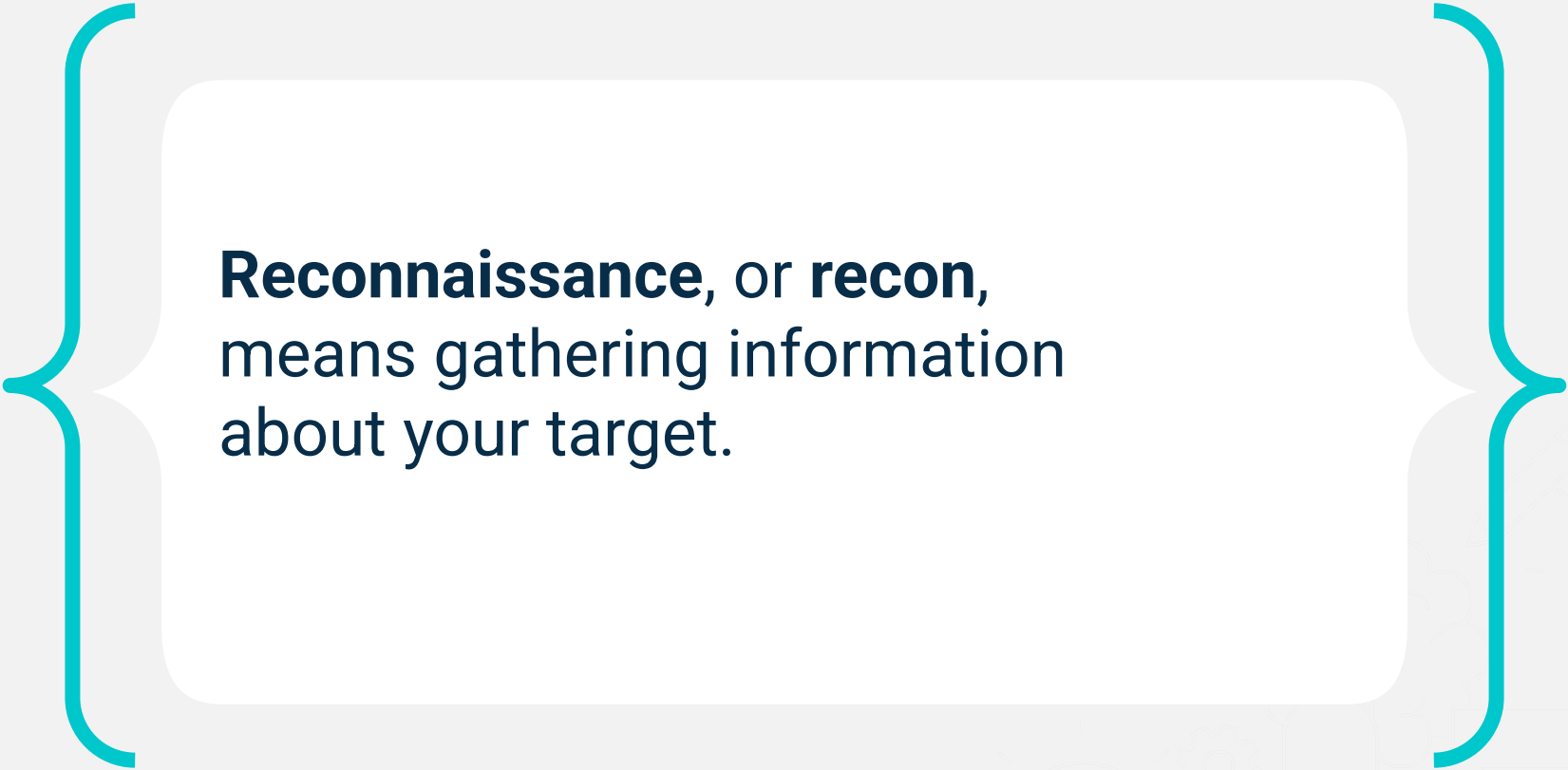




Reconnaissance with OSINT and Google Hacking



Reconnaissance is the first
MITRE ATT&CK tactic.



Reconnaissance, or recon,
means gathering information
about your target.



Reconnaissance

Reconnaissance is divided into two types:

01

Passive Recon

Often refers to **open source intelligence (OSINT)**, which leverages information about the target that is publicly available on the internet.

This includes all domains and hosts belonging to a target that are publicly viewable.

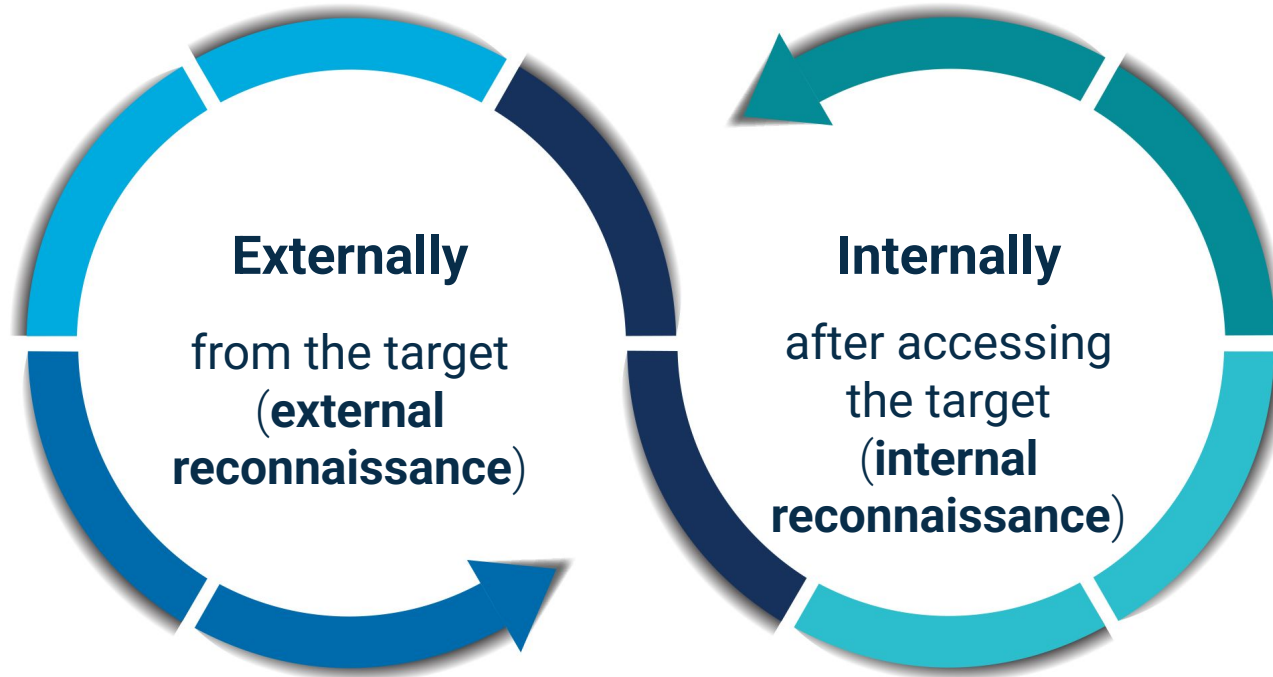
02

Active Recon

Also refers to gathering information about the target, but it involves directly interacting with the target.

Reconnaissance

Reconnaissance can be conducted:





Enables us to manipulate Google searches to narrow down our queries
in order to acquire actionable intel.



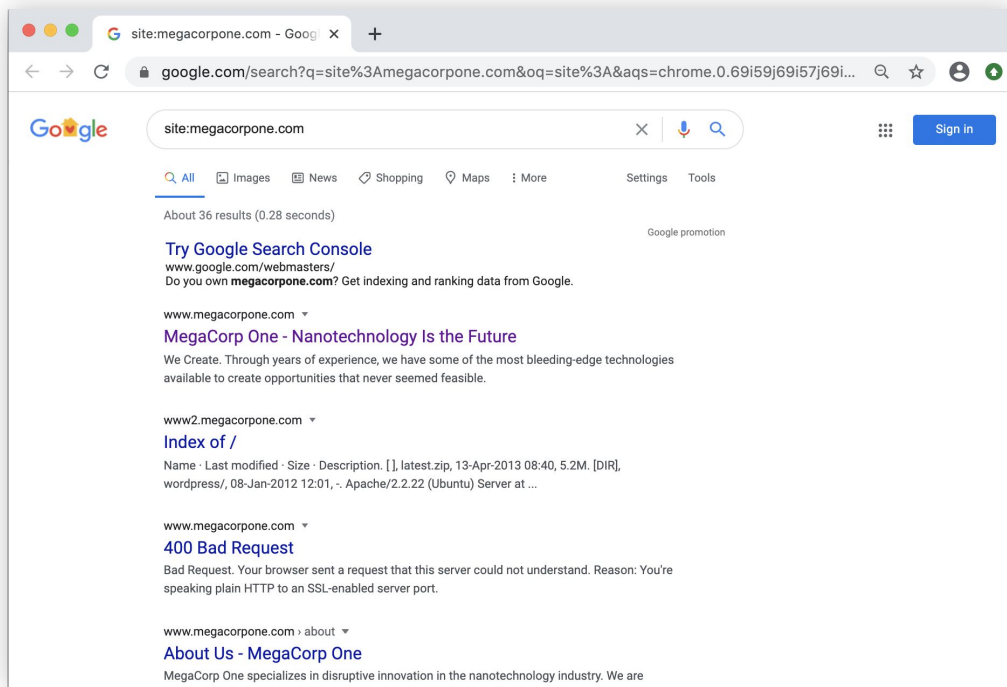
Falls under the technique:
Search Open Websites/Domains: Search Engines, ID T1593-002.

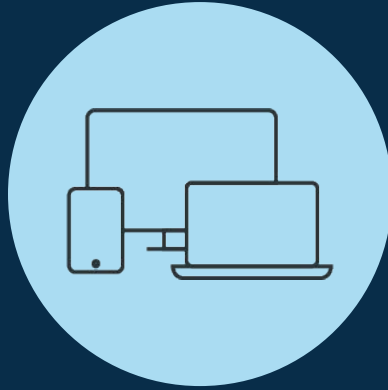


Demonstration Scenario

In this demonstration, we'll use Google hacking basic functionality to target sans.org.

Then you will apply this tool to gather OSINT in the next activity.





Instructor Demonstration

Google Hacking



Summary

We've covered the following concepts:

Reconnaissance	Gathering information about your target. It's part of the Planning and Reconnaissance phase.
Passive Recon	Leveraging information about the target that is publicly available on the internet. Often refers to open source intelligence (OSINT) .
Active Recon	Directly interacting with the target to obtain information.
External Reconnaissance	Reconnaissance that is conducted externally from the target.
Internal Reconnaissance	Reconnaissance that is conducted internally after accessing the target.
Google Hacking	A reconnaissance tactic that enables us to manipulate Google searches to narrow down our queries to acquire actionable intel.



Activity:

Google Hacking

As a penetration tester for GoodCorp, you have been tasked with conducting an engagement against the fictional company MegaCorpOne.

- You will start by using Google hacking to find information pertaining to MegaCorpOne.

Suggested Time:
15 Minutes



Time's up!
Let's review



Questions?





Break
15 mins



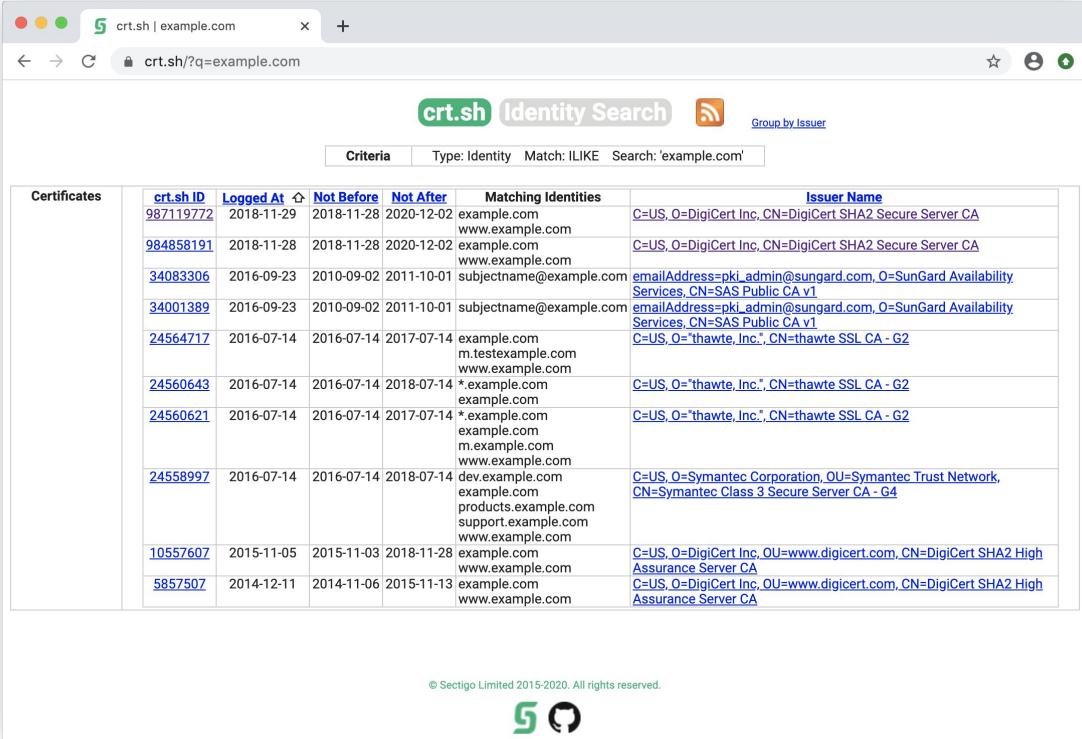
Certificate Transparency

Certificate Transparency

Certificate issuers publish logs of SSL/TLS certificates that they issue to organizations.

This is known as **certificate transparency**. Attackers can exploit it to search for subdomains.

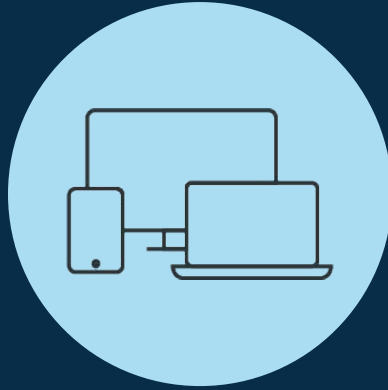
This falls under the **Search Open Technical Databases: Digital Certificates** MITRE technique, ID T1596.003.



The screenshot displays the crt.sh Identity Search interface. The browser address bar shows 'crt.sh | example.com' and the URL 'crt.sh/?q=example.com'. The page features a search bar with the criteria 'Type: Identity', 'Match: ILIKE', and 'Search: example.com'. Below the search bar is a table of certificates.

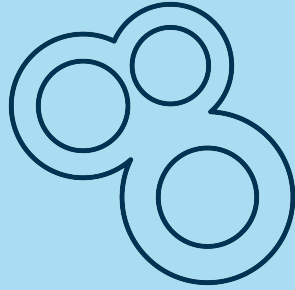
Certificates	crt.sh ID	Logged At	Not Before	Not After	Matching Identities	Issuer Name
	987119772	2018-11-29	2018-11-28	2020-12-02	example.com	C=US, O=DigiCert Inc, CN=DigiCert SHA2 Secure Server CA
	984858191	2018-11-28	2018-11-28	2020-12-02	www.example.com	C=US, O=DigiCert Inc, CN=DigiCert SHA2 Secure Server CA
	34083306	2016-09-23	2010-09-02	2011-10-01	example.com	C=US, O=DigiCert Inc, CN=DigiCert SHA2 Secure Server CA
	34001389	2016-09-23	2010-09-02	2011-10-01	subjectname@example.com	emailAddress=pki_admin@sungard.com, O=SunGard Availability Services, CN=SAS Public CA v1
	24564717	2016-07-14	2016-07-14	2017-07-14	subjectname@example.com	emailAddress=pki_admin@sungard.com, O=SunGard Availability Services, CN=SAS Public CA v1
	24560643	2016-07-14	2016-07-14	2018-07-14	example.com	C=US, O="thawte, Inc.", CN=thawte SSL CA - G2
	24560621	2016-07-14	2016-07-14	2017-07-14	m.testexample.com	C=US, O="thawte, Inc.", CN=thawte SSL CA - G2
	24558997	2016-07-14	2016-07-14	2018-07-14	www.example.com	C=US, O="thawte, Inc.", CN=thawte SSL CA - G2
	10557607	2015-11-05	2015-11-03	2018-11-28	example.com	C=US, O=Symantec Corporation, OU=Symantec Trust Network, CN=Symantec Class 3 Secure Server CA - G4
	5857507	2014-12-11	2014-11-06	2015-11-13	dev.example.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
					products.example.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
					support.example.com	
					www.example.com	

© Sectigo Limited 2015-2020. All rights reserved.



Instructor Demonstration

Certificate Transparency



Shodan.io

Shodan.io

Shodan.io conducts port scanning across the entire internet and catalogs the results for quick searching.

This saves us the time we would spend conducting a port scan. Not conducting the scan also allows us to keep our originating IP address hidden.

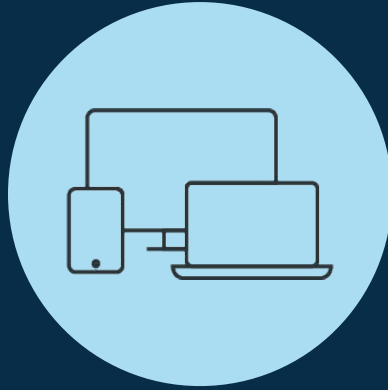
This falls under the MITRE technique **Search Open Technical Databases: Scan Databases, ID T1596.005.**

The screenshot shows the Shodan.io website interface. The browser address bar displays 'shodan.io/host/93.184.216.34'. The website header includes navigation links like 'Shodan', 'Developers', 'Monitor', 'View All...', 'Explore', 'Pricing', 'Enterprise Access', 'New to Shodan?', and 'Login or Register'. A search bar with the Shodan logo is prominent. Below the header is a satellite map of a coastal area with labels for 'Canton', 'Randolph', 'Stoughton', 'Avon', 'Rockland', 'Norwell', 'Wills Island', and 'Hanover'. The main content area is titled '93.184.216.34' and features a table with the following data:

City	Norwell
Country	United States
Organization	Verizon Business
ISP	Verizon Business
Last Update	2020-04-24T17:31:40.422234
ASN	AS15133

To the right of the table, there are sections for 'Ports' and 'Services'. The 'Ports' section shows two blue boxes with the numbers '80' and '443'. The 'Services' section shows a green box with a white arrow icon and a list of service details:

- HTTP/1.1 200 OK
- Age: 354667
- Cache-Control: max-age=604800
- Content-Type: text/html; charset=UTF-8
- Date: Fri, 24 Apr 2020 17:31:40 GMT
- Etag: "3147526947+ident"
- Expires: Fri, 01 May 2020 17:31:40 GMT
- Last-Modified: Thu, 17 Oct 2019 07:18:26 GMT
- Server: ECS (bsa/EB11)
- Vary: Accept-Encoding
- X-Cache: HIT
- Content-Length: 1256



Instructor Demonstration

Shodan.io

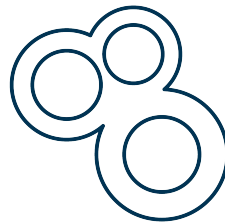
MITRE ATT&CK®

We've covered the following concepts:



Certificate Transparency

A reconnaissance tactic whereby a penetration tester can gather information from certificate issuers, who publish logs of the SSL/TLS certificates that they issue to organizations.



Shodan.io

A reconnaissance website that conducts port scanning across the entire internet and catalogs the results for quick searching.



Activity:

Shodan.io

In this activity, you will continue to play the role of a pen tester conducting an engagement on MegaCorpOne.

- You are now tasked with performing OSINT by using Shodan.io.

Suggested Time:
15 Minutes

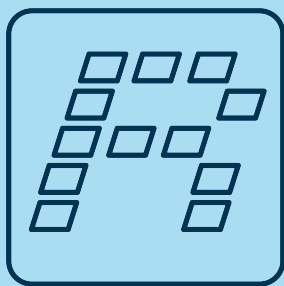


Time's up!
Let's review



Questions?





recon-ng



Let's recap



Recap

Steps we have taken so far:

01

We undertook the planning part of the planning and reconnaissance phase.

02

We began passive reconnaissance by using **Google hacking**.

03

We used **Shodan.io** to view previously completed port scans on several targets.

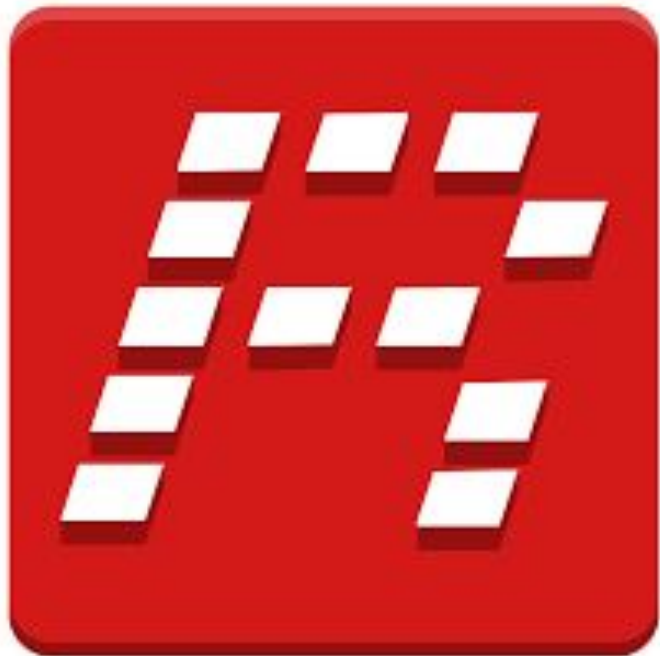


Now we'll continue our reconnaissance efforts with another tool called **recon-ng**.



recon-ng

recon-ng is a web reconnaissance framework written in Python



Recon-ng provides a powerful, open-source, web-based framework for conducting reconnaissance quickly and thoroughly. It includes the following features:

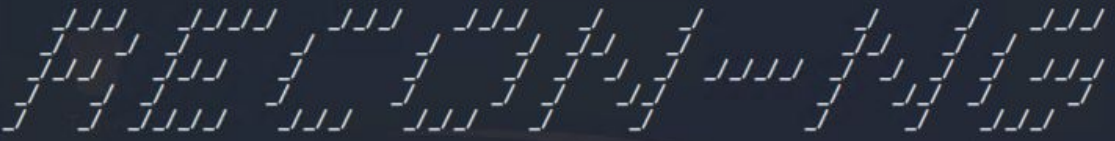
- Independent modules
- Database interaction
- Built-in convenience functions
- Interactive help
- Command completion



recon-ng

There are many scripts that can assist with integrating OSINT tools into recon-ng

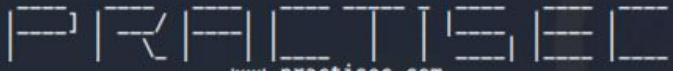
```
sysadmin@kali:~$ recon-ng
[!] 'shodan_api' key not set. shodan_ip module will likely fail at runtime. See 'keys add'.
[*] Version check disabled.
```



```
Sponsored by ...
```



```
www.blackhillsinfosec.com
```

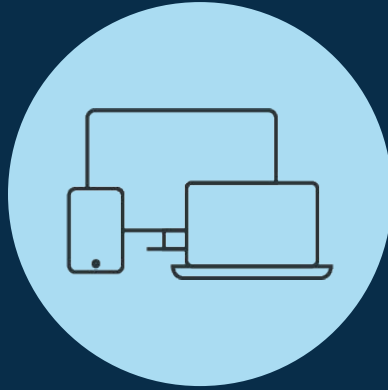


```
www.practisec.com
```

```
[recon-ng v5.1.1, Tim Tomes (@lanmaster53)]
```

```
[2] Recon modules
```

recon-ng is a framework that ingests a lot of popular OSINT modules, allowing the results of multiple tools to be combined into a single report.



Instructor Demonstration

recon-ng



Activity:

recon-ng

In this activity, you will continue to play the role of a pen tester conducting an engagement on MegaCorpOne.

- You are tasked with determining whether MegaCorpOne's domain server info is accessible using OSINT tools.
- You will use the Shodan API and **recon-ng** to perform your tests, and then you'll place all of your findings in a report.

Suggested Time:
15 Minutes



Time's up!
Let's review



Questions?





Next class

Initial Access and Internal Recon



Thank you